

SoK: Acceptance Is Not Action

Where agent containment actually binds

Anonymous Submission

Under double-blind review

Anonymous submission — under double-blind review

Anonymization note. Author, affiliation and the identity of companion submissions are withheld for double-blind review. Citations of the form [Anon-∗] are unpublished companion work by the same authors and are anonymized accordingly; **all third-party citations are intact**. Pre-registration hashes are retained deliberately: they are this paper's evidence of pre-registration, and a SHA-256 identifies a frozen document rather than a person.

Submitted to IEEE SaTML 2027. Anonymized for double-blind review.

Open Science. The corpus table with per-cell verbatim spans, the full inter-coder disagreement record, the compatibility-matrix derivation, the frozen action-surface enumeration and the coding instrument are released as an anonymized artifact. No component of this work requires access to non-public data.

Adjudicating the guarantees of execution controls for autonomous coding agents

ABSTRACT

Autonomous coding agents execute code, write files, spawn subprocesses, install packages and reach the network. A large and fast-growing literature proposes controls to contain them. That literature has been catalogued; it has not been adjudicated.

We systematize execution controls for autonomous coding agents along three orthogonal axes and, in doing so, perform two measurements the literature does not report. First, we apply a **weakest-link tier rule**: each control is scored at the *lowest* enforcement tier at which its guarantee can be defeated — cryptographic, operating-system, or application-proxy — rather than the tier it advertises. Second, we **derive mediation coverage** for each system against a frozen enumeration of the coding-agent action surface, because no work in the corpus reports it. We further classify each work by **adversary placement** relative to its interposition point, which yields our central composition result: two controls compose only if their assumed adversary placements are compatible, and a specific, nameable set of published guarantees do not.

We apply Schneider's enforceability result to the corpus and identify claimed policies outside the class any execution monitor can enforce. We grade every work's evidence level from claim-only to reproducible bypass. **One scored system is subject to a declared conflict of interest; it is scored under**

the same procedure as every other row, and it does not survive that procedure intact.

The central result. Across 15 systems re-scored under a two-column tier rule, **the cryptography in this literature binds acceptance, not action**. Seven systems make a claim whose forgery requires breaking a signature, a hash chain or an attestation — **tier T1 of acceptance**. Only one bounds an action cryptographically. **Eleven bound actions only where they traverse an application chokepoint**. The modal pattern, five of fifteen, is **A-T1 over B-T3**: a strong cryptographic claim about what a relying party will accept, resting on an application-layer bound on what the process can do. We name that pattern the **authorization–execution gap**, and show it has a composition consequence: such a system delivers its advertised guarantee only atop an operating-system substrate it does not itself provide. The corpus contains both halves and almost no system that is both.

Two findings the corpus did not want to give up. Tier T2 of acceptance is empty — no system makes acceptance turn on a kernel-mediated fact. And the best-placed candidate in the set, an Intel TDX trusted plane, fails to populate T1 of acceptance at all: the rhetoric is unforgeability, the cryptographic construction binding the token is never given, and the verifier is untrusted.

Supporting results (25 works, 50 codings, full text on 50 of 50). Under the action column, **12 of 14 systems with a scorable advertised tier bind lower than they advertise**, five by two tiers. **Two of 105 coverage cells reach covered (1.9%)** — thirteen of fifteen systems fully mediate nothing. **Network egress is reached by 14 of 15 systems and bounded completely by none**. And the enforceability verdict is **split on 50 of 50 codings** across every tier the corpus contains: a monitorable safety surrogate enforced beneath a non-monitorable advertised objective. Not modal. Universal.

△ **The instrument was wrong first, and we report that.** A single-column weakest-link rule collapsed every cryptographic system to the application tier, because "defeated by an actor that never consults the verifier" and "defeated by any path that does not traverse it" are the same sentence for an agent-side guarantee. §3.1.1 states the defect and the repair. The repair was validated against a prediction made before it ran: coders had recorded a narrower genuinely-T1 guarantee in four of five cryptographic works, and **exactly those four rise to T1 of acceptance**.

Selection caveat: the fifteen were chosen for tier-axis power,

so demotion rates are upper bounds and are never reported as corpus rates. Full corpus pass follows the 15 November freeze.

1. INTRODUCTION

An autonomous coding agent is a language model with a tool loop and a shell. It edits files, runs builds, installs dependencies, pushes commits and calls networks — and it decides, within a task, which of those to do next. The security question is not whether it will take an action nobody anticipated. It is what happens when it does.

A substantial literature has grown to answer that. It spans sandbox isolation, capability and access control, policy enforcement, time-of-check/time-of-use defenses, protocol-level threat analysis, identity and delegation, execution provenance and network egress control. It has recently been systematized: arXiv:2607.05743 organizes 39 papers from 2023–2026 into 17 categories and reports, among other findings, that policy enforcement fails at rates between 69% and 98%, and that up to 17.1% of benign actions fall out of scope under realistic prompting.

That systematization is a taxonomy, and this paper is not another one. Organizing by topic tells a reader what has been studied. It does not tell them whether the guarantees hold, whether two controls can be deployed together, or how much of an agent's behavior any control actually sees.

Those are adjudication questions, and they are unanswered.

1.1 What this paper does differently

We state this on page one deliberately. A reviewer who has read 2607.05743 and reaches our page six without seeing it named will stop reading, and they would be right to.

1.2 Contributions

1. **The weakest-link tier rule** (§3.1) and its application to the corpus. A control that signs its mandates but enforces them in an in-process hook is proxy-tier, because forging the signature is unnecessary when the hook can be bypassed. This rule prevents the "hybrid" bin into which prior taxonomies in this space have dissolved.
2. **Derived mediation coverage** (§3.2) against a frozen seven-effector enumeration. This is a measurement the SoK performs, not a classification of what authors claim.
3. **Adversary placement** (§3.3) as a partition, and the **composition compatibility result** it makes possible (§6).
4. **Application of Schneider's enforceability result** (§7) to identify claimed policies that no execution monitor can enforce.
5. **An evidence grade** per work (§3.4), L0 claim-only to L3 reproducible bypass, and the observation this permits about enforcement claims that have never been tested above L1.
6. **A small empirical artifact** (§8) demonstrating bypass on representative systems, one per tier.

2. SCOPE, AND THE CLASSICAL SPINE

2.1 Inclusion

A work enters the corpus if it: **(G1)** targets autonomous or semi-autonomous agents that execute code or invoke tools with side effects; **(G2)** proposes, implements or evaluates a control intended to constrain those effects; **(G3)** states a threat model naming an assumed-compromised component; and **(G4)** makes an authority or tamper-evidence claim, not merely a visibility claim.

G4 is doing real work. It excludes agent-observability systems whose only claim is that you can see what happened. Those matter, and they are not controls.

2.2 Exclusion

Excluded: alignment and training-time safety; content moderation and guard models, which operate on content rather than capability and are surveyed elsewhere; general LLM security without an execution surface; and position papers without a mechanism.

2.3 The classical spine — positioning, never rows

Complete mediation, least privilege, confinement, execution monitors and capability confinement enter this paper **without a date bound and without tiering**. They are the evaluative vocabulary and the positioning apparatus. They are never scored as corpus rows and never coverage-graded.

We say so explicitly because SoK reviewers look for exactly this discipline, and because a systematization that tiers Saltzer and Schroeder alongside a 2026 preprint has confused its own categories.

The classical results that do real work here:

- **Complete mediation** is the property our coverage axis measures the absence of.
- **Confinement** in Lampson's sense names what a proxy-tier control cannot achieve.
- **Schneider's enforceability result** bounds what any execution monitor can enforce, and §7 applies it to claimed policies in the corpus.
- **Anderson's three properties** of a reference monitor — tamperproof, always invoked, small enough to verify — are the cross-cut in §6.4.

3. THE THREE AXES

3.1 Axis 1 — Enforcement tier, under the weakest-link rule

Three tiers, distinguished by what defeats them:

The rule. A work is scored at the lowest tier at which its guarantee can be defeated, not the tier it advertises.

Worked example. A system issues cryptographically signed capability mandates and enforces them via an in-process hook in the agent harness. It presents as T1. It scores **T3**, because an adversary need not forge a signature when the hook can be bypassed by a subprocess that never calls it. The cryptography is real and it constrains a different adversary than the one the system faces.

	arXiv:2607.05743 (Jul 2026)	This paper
Organizing principle	17 topical categories	3 orthogonal axes, each partitioning
Tier treatment	none	weakest-link scoring — lowest tier at which the guarantee falls
Coverage	not addressed	derived against a frozen action surface
Threat placement	per-paper, unaggregated	adversary placement as a partition
Composition	not addressed	pairwise compatibility as the central result
Enforceability theory	not applied	Schneider applied to claimed policies
Evidence quality	not graded	L0–L3 per row
Authors' own system	n/a	scored first, at full severity

Tier	Binds	Defeated by
T1 Cryptographic	What a compliant verifier will accept	An actor that never consults the verifier
T2 Operating system	What the process can do, regardless of intent	Kernel vulnerability, misconfiguration, over-broad capability
T3 Application proxy	What passes the chokepoint	Any path that does not traverse it

Why this rule is the paper. Every prior taxonomy over this literature dissolves into a "hybrid" category once systems combine mechanisms. Weakest-link scoring refuses the hybrid bin. It also produces a testable prediction: **systems marketed as enforcing bind, in the majority of cases, only at a chokepoint — and a chokepoint bound ends at the first subprocess spawn.** On the scored set the rule demotes **12 of 14 works with a scorable advertised tier**, one work being unscorable under the mechanism-specificity floor. That rate is an upper bound rather than a corpus rate: the fifteen were selected for tier-axis power, not sampled.

3.1.1 △ The T1/T3 collapse, and the repair: **The decisive pass found that the rule as stated above cannot measure its own top tier.** Five works advertised cryptographic enforcement. All five scored T3. In four of the five, the coder who scored T1 wrote in the same record that a *narrower* guarantee in the same paper is genuinely T1 and proved.

The cause is textual, not empirical:

*T1 is "defeated by an actor that never consults the verifier."
T3 is "defeated by any path that does not traverse it." For an agent-side guarantee these are the same sentence.*

Any work claiming a compromised agent *cannot act* outside its authority is therefore T3 by construction, however sound its cryptography, because the agent can always write a file. The rule could not distinguish two very different situations: **the cryptography does not bind execution** — a real finding, and the one §9 makes about the authors' own system — from **the guarantee happened to be phrased in agent-side terms**, which is a sentence-level accident.

The repair is one column split into two.

A signed capability token can be **T1 of acceptance and T3 of action** simultaneously, and saying so is more informative than either verdict alone. It also states the §9 system's position precisely: its receipts are T1 of acceptance, its enforcement is T3 of action, and the gap between those two columns is what that section is about.

Plus a mechanism-specificity floor. A tier claim is scorable only where the paper names the mechanism that would have to fail. Works that gesture at a mechanism without an interposition point are recorded as *unscorable*, not silently demoted —

which is what happened to one work in this pass and should not have.

Outcome of the re-score, run 2026-08-30 over all 15 works. The repair is discriminating rather than permissive, which is the test that matters — a fix that promoted everything would be worthless.

Validated against a prior prediction. Before the re-score, coders had independently recorded that four of the five cryptographic works contained a *narrower* guarantee that is genuinely T1 and proved. **Exactly those four rise to A-T1.** All seven works with a recorded narrower guarantee score A-T1; **zero works without one were promoted**; and one recorded guarantee was declined on a stated criterion. The repair therefore tracks evidence gathered before it existed, which is the difference between a fix and a rationalization.

Six works remain A-T3/B-T3. The old rule was right about them. The repair does not rescue systems whose rhetoric outran their mechanism — it separates them from systems whose cryptography was real and was being measured against the wrong question.

Re-scoring obligation. Every tier cell scored under the single-column rule is re-scored under the two-column rule before entering a finding. This is a rule change discovered by measurement, and it is disclosed as such rather than presented as the design.

Assignment procedure. For each work: enumerate the guarantee as stated; identify the mechanism that would have to fail for it not to hold; identify the cheapest adversary action that causes that failure; assign the tier of the mechanism that action defeats. Every assignment carries a quoted span from the source. Disagreements between coders are adjudicated on the record and published.

3.2 Axis 2 — Mediation coverage, derived

No work in the corpus reports coverage. Extraction from author claims is not viable, because authors describe what their control mediates rather than what fraction of the agent's action surface that represents. So the SoK derives it.

The frozen action surface. Seven effectors, frozen 2026-08-30 as ACTION-SURFACE-v1.0 and published with the artifact. That document also reconciles this enumeration with

Column	Question	Sandlock example
Tier of acceptance	At what tier is a <i>claim</i> verified — what will a relying party accept?	n/a (no signed claim)
Tier of action	At what tier is an <i>action</i> bounded — what stops the process?	T2 (kernel)

Column A — acceptance	n	Column B — action	n
A-T1 cryptographic	7	B-T1 cryptographic	1
A-T2 operating system	0	B-T2 operating system	2
A-T3 application	7	B-T3 application	11
A-NONE	1	unscorable	1

[Anon-D]’s instrumentation classes, so the derived scores here and the measured score in §9 share a denominator:

Coverage for a system is the subset of {E1...E7} its guarantee reaches, at its assigned tier, with a quoted justification per cell.

This axis is either the paper’s best contribution or its fatal weakness, and the difference is entirely procedural. Therefore:

- The enumeration is **frozen and published before coding**, not adjusted as the corpus is read.
- **Two independent coders**, with Cohen’s κ reported and every disagreement adjudicated on the record.
- **Every derived cell is traceable to a quoted span in the source paper**. A cell with no span is not recorded. We borrow this discipline from AgentThread’s validator design, which rejects any record whose source span is absent from the document.

Without that procedure a reviewer calls this the authors’ opinion rendered as a heatmap, and they are right.

3.3 Axis 3 — Adversary placement

Where does the work assume the attacker sits, relative to the interposition point?

Why this axis and not "evidence model." An earlier design used evidence model as axis 3. It collapses: isolation, capability, policy-enforcement and TOCTOU papers make no tamper-evidence claim at all, so the column reads *none* for most rows and populates almost exclusively in the receipts and attestation cluster — **which is the present authors’ own research area**. An axis whose only populated cells are the authors’ own work reads as a systematization arguing toward its sponsor, and it hands a reviewer the most damaging thing they can say about an SoK from an organization that ships in the space.

Adversary placement is the correct substitution on four grounds: it is **extractable** rather than derived, since G3 already requires a stated threat model; it **partitions the corpus differently from axis 1**, which is what an axis must do to earn its place; it is the **instrument of the composition result** in §6; and it is precisely the ground the protocol-composition literature leaves open, since that work assumes its transport substrate and places no adversary below the protocol layer.

3.4 Evidence grade — a column, not an axis

Every row carries a grade:

This is deliberately demoted from an organizing axis to a reported column. It preserves the real question — enforcement claims are under-tested — without giving it structural weight the corpus cannot support. It also sharpens a finding: given that the prior systematization reports policy enforcement failing at 69–98%, **how many works claiming enforcement have ever been graded above L1?** Across the 15 works: **L0 claim-only 4, L1 source-inspection 0, L2 behavioral confirmation 13, L3 reproducible bypass 3** (counts over 20 pilot codings; the decisive-pass grades agreed 15 of 15 between coders). **The empty L1 cell is itself informative**: works in this literature tend either to assert a guarantee or to test it behaviorally, and the intermediate practice of verifying a mechanism by inspection without testing it is close to absent. The L3 material is concentrated in attack papers rather than in defenses re-testing themselves.

3.5.2 Coding method: machine coding, disclosed, with human verification on load-bearing rows

SaTML requires an **LLM usage considerations** section. Ours is not incidental, so it is stated here as method rather than confessed in a limitations paragraph.

All 15 works were coded by two LLM agents given opposed stance prompts — one conservative, one charitable to the authors — each required to retrieve full text and produce verbatim spans. Full text was retrieved on 30 of 30 codings.

What that is, stated precisely. Agreement between two prompts of one model family is **not inter-coder reliability**. The two share failure modes and will agree on the same misreadings, so their agreement rate is an **upper bound** on reliability rather than an estimate of it. Every agreement figure in this paper is labeled accordingly, and a Cohen’s kappa is reported only where the marginals support one — which for the coverage axis they do not.

The verification layer. Machine coding alone is insufficient for rows that carry findings. Every work supporting a headline claim — nine of fifteen — is **verified by a human coder against the recorded spans**, who confirms, corrects or rejects each verdict. The count of **overturned rows is reported** in this section. A non-zero count is evidence the layer is real rather than ceremonial; a zero count would itself require explanation.

Three things the machine layer does that a human layer would not.

1. **Opposed stances by construction.** Two humans bring whatever priors they have. Two prompts bring priors we specified and can publish, which makes the divergence interpretable.
2. **Mandatory spans.** A cell without a verbatim span is not recorded. That constraint is trivial to impose on an agent and awkward to impose on a person, and it is what makes

	Effector	Note
E1	File write	Including rename and unlink
E2	Subprocess spawn	Including descendants — the exclusion that inflates coverage most
E3	Network egress	By the agent or any descendant
E4	VCS push	Distinguished from E1 because its blast radius leaves the machine
E5	Package install	The supply-chain effector
E6	Credential use	Environment, config, keychain, metadata endpoint
E7	Sub-agent spawn	Delegation, where authority propagates

	Placement	Typical class
A1	Outside the system entirely	Perimeter and egress controls
A2	In inputs or retrieved context	Indirect injection defenses, tool-output screening
A3	In the agent's policy or weights	Misaligned or compromised model; behavioral bounds
A4	Inside the harness or orchestrator process	In-process hooks, protocol-layer policy, TOCTOU
A5	Below the harness	Kernel, hypervisor, supply chain, package install

	Level	Meaning
L0	Claim only	The guarantee is asserted
L1	Source inspection	Mechanism verified by reading the implementation
L2	Behavioral confirmation	Guarantee tested against constructed cases
L3	Reproducible bypass	The guarantee has been broken, reproducibly, by someone

human verification a four-hour task rather than a re-reading of fifteen papers.

3. **Divergence as measurement.** The rate at which opposed-stance coders diverge, and where, is reported as a result. On this corpus it was concentrated rather than diffuse: near-total agreement on evidence grade and enforceability, and 29.5% disagreement on coverage cells running **entirely in one direction**. That pattern diagnosed a defect in our own rubric that neither stance alone would have surfaced.

The honest summary for a reviewer. This is machine-extracted, human-verified adjudication. It is not a human systematization, and it does not claim to be. We think the trade is favorable at this corpus size, and we report enough for a reader who disagrees to discount it precisely.

4. METHOD

Screening. ~60 candidates identified by systematic search across cs.CR, cs.AI and cs.SE, plus citation chasing from the prior systematization and from the classical spine. Screened to ~45 by full-text application of G1–G4. **Expected attrition 10–20%**, and the excluded set is published with the gate that excluded each.

Full-text only. No work is scored from an abstract. This is stated as a method commitment because the failure mode is real and we have committed it elsewhere in the companion studies: a related-work section built from abstracts is both a desk-reject risk and an integrity problem.

Coding. Two coders, independent, on all three axes plus the evidence grade. Cohen's κ per axis. Disagreements adjudicated by discussion, on the record, published in the artifact.

Corpus freeze: 15 November 2026. Works appearing after the freeze are noted in a postscript and not scored, so the corpus is a stated population rather than a moving one.

Category	n	Share
Policy enforcement	17	35%
Sandbox	8	16%
Delegation	7	14%
Capability	6	12%
Protocol	4	8%
TOCTOU	4	8%
Egress	2	4%
Provenance	1	2%

5. THE CORPUS

***Pilot-populated 2026-08-30.** Numbers below carry their sample size. The full coverage pass runs October–November; corpus freeze 15 November. Nothing here is a final result and every figure is labeled with what produced it.*

5.1 Screening

322 candidate records were produced by four independent discovery modalities — mechanism-first search, systematic database sweep, venue and industry search, and seed mining from the prior systematization. **55 were screened; 49 included, 6 excluded.**

△ **The remaining 267 candidates were not screened.** The screening payload truncated at the 55th record. This is a process defect, not a scope decision, and it is disclosed rather than absorbed: the delegation and TOCTOU clusters are expected to grow, and the corpus is **not closed**. No attrition rate is reported, because §4's commitment to publish the excluded set with per-work gate attributions is only partly discharged.

The 89% inclusion rate on the screened slice reflects a pool that arrived pre-filtered with per-item scope rationales. It is not evidence that the gates were applied loosely; every exclusion is a recorded gate failure.

5.2 Composition of the screened corpus (n = 49)

By year: 2024 — 1 (2%); 2025 — 16 (33%); **2026 — 32 (65%)**. Only one pre-2025 work survives the gates. The field

Venue type	n	Share
arXiv preprint	48	98%
Peer-reviewed venue	1	2%

is under two years old and accelerating.

5.3 ★ *The corpus is 48 preprints and one peer-reviewed paper*

This is a finding, not a housekeeping note, and it conditions everything downstream. **An unreviewed claim of "provable," "verifiable," "mandatory" or "kernel-level" has had no external check.** The evidence-grade column in §3.4 exists precisely because such claims are, in this literature, the default rather than the exception — and because the one work that did pass peer review is also one of the works that demotes (§5.4).

5.3A ★ *The authorization–execution gap*

Five of fifteen systems score A-T1 over B-T3: forging the *claim* requires breaking a signature; bounding the *action* requires only a path that avoids a chokepoint. This pattern is unrepresentable under a single-column rule, which is why it had not been named.

It has a composition consequence, and it is the paper's central one:

An A-T1/B-T3 system delivers its advertised guarantee only on top of a B-T2 substrate it does not itself provide. The cryptography is sound and it is answering a question about acceptance. The question the deployment needs answered is about action.

The corpus contains both halves and almost nothing that is both. Sandlock is A-NONE/B-T2 — a real kernel bound making no verifiable claim to anyone. The five A-T1/B-T3 systems are verifiable claims with no kernel bound. **One work is both**, and how it got there is instructive: PAuth achieves B-T1 *topologically*, by placing the verifier outside the adversary's address space rather than by strengthening the cryptography.

Two negative results sharpen it.

A-T2 is empty. Not one system in the corpus makes acceptance turn on a kernel-mediated fact — a real uid, a namespace membership, a measured boot value. Acceptance is either cryptographic or application-level, and the middle is unoccupied.

The best-placed candidate does not populate A-T1. An Intel TDX trusted plane — the only work interposing below the harness, and the one most likely on its face to hold a hardware-rooted acceptance claim — scores A-T3. The rhetoric is unforgeability; the construction binding the token is never given; the verifier is untrusted. That is stated first among the results rather than buried, because it is the result least convenient to the framing.

5.4 *The action column: advertised against scored*

△ **Relabeled.** The demotion statistic below is an **action-column** measurement. Under the single-column rule it was reported as *the* tier result; §3.1.1 shows that rule could not see the acceptance column at all, so the figure measures less than it appeared to.

Two passes. Every coding retrieved full text: **50 of 50.**

△ **The two passes are not like-for-like.** The pilot sampled the prompt-injection cluster, which is largely tier-honest. The decisive pass was selected for tier-axis power — six demotion candidates, six T2 anchors, three T1 candidates. **The 85.7% figure is an upper bound and must never be reported as a corpus rate.**

Exactly one work scores above T3: Sandlock, T2, unanimous across both coders. It is also the only work in the set whose prose declines to overclaim — a correlation worth stating and too small a sample to lean on.

Five of the six deliberate T2 anchors demoted, **and for five structurally different reasons**, each quoted. The through-line is a sentence the paper did not previously contain:

Tier is set by the weakest placement step, not by the strongest enforcement mechanism.

A system can hold a genuine kernel boundary in one limb and lose the guarantee at a configuration step, a userspace resolver, or a trusted-path assumption elsewhere. That is what weakest-link scoring is for, and it is what a taxonomy organized by mechanism cannot see.

5.5 Coverage

2 of 105 adjudicated cells scored covered — 1.9%. Both belong to Sandlock (E1, E2). **Thirteen of fifteen systems fully mediate nothing.** The modal cell is *partial*.

△ This supersedes the earlier pass's 17 of 140 (12.1%). **The number moved by an order of magnitude in the unflattering direction** once OS-tier and cryptographic-tier systems were coded under the v1.1 depth rule.

The E2 prediction was wrong, and the replacement is better. §3.2 called E2 subprocess spawn "the exclusion that inflates coverage most" and predicted it would be least covered. It is third (8 of 15 *not-covered*), behind **E5 package install (12 of 15)** and **E4 VCS push (11 of 15)**.

The sharper finding sits beside it:

Network egress is reached by 14 of 15 systems and scored covered by none of them.

Every system in the set touches egress. Not one bounds it completely. That is a stronger sentence than the E2 claim it replaces and it lands on the same reference-monitor target in §6.4.

Coverage-cell agreement: 74 of 105 (70.5%), against 64.3% under v1.0 in the pilot. The v1.1 three-value rubric **eliminated the entire label-collision class** — zero pure collisions remain. The residual 29.5% is depth-of-mediation judgment, and **all 31 disagreements ran one direction**, with the charitable coder scoring higher every time. A one-directional residual is a rubric signal, not noise: the depth rule is being read as a floor by one stance and a ceiling by the other, and §5A needs one more sentence before the full pass.

	Pilot (10 works)	Decisive pass (15 works)
Demotion rate	4 of 10 (40%)	12 of 14 scorable (85.7%)
Two-tier falls	0	5
Works scoring above T3	0	1
Scored-tier agreement	6 of 6 (100%)	11 of 15 (73.3%)

Grade	n
L0 claim only	4
L1 source inspection	0
L2 behavioral confirmation	13
L3 reproducible bypass	3

Placement	As primary	As secondary
A1 outside the system	2	13
A2 in inputs or retrieved context	10	4
A3 in the agent's policy or weights	1	11
A4 inside the harness	2	7
A5 below the harness	0	7

	A1	A2	A3	A4	A5
A1	✓	✓	✓	△	△
A2	✓	✓	△	×	×
A3	✓	△	✓	△	×
A4	△	×	△	✓	△
A5	△	×	×	△	✓

	n	Share
Compose	69	66%
Conditional	16	15%
Do not compose	20	19%

5.6 Evidence grades (pilot, 20 codings)

The empty L1 cell is informative. Works in this literature tend either to assert a guarantee or to test it behaviorally; the intermediate practice of verifying a mechanism by inspection without testing it is nearly absent. Screening locates the L3 material in five rows — two defense-breaking papers and three TOCTOU exploitation papers — which means **reproducible bypass evidence in this field is produced almost entirely by attack papers rather than by the defenses re-testing themselves.**

6. THE COMPOSITION RESULT

6.1 The claim

Two controls compose only if their assumed adversary placements are compatible. A control assuming A2 and a control assuming A4 do not compose: the first assumes the harness is trustworthy and screens what enters it; the second assumes the harness is compromised. Deploying both does not yield the union of their guarantees. It yields the weaker one over any action reachable at the weaker placement.

6.2 The placement distribution, and what it already shows

Primary placement is the adversary a work's **evaluation actually tests**. Secondary placements are those its design addresses but does not test. Coder agreement on primary placement: **12 of 15 (80%)**.

Three results, and the first vindicates a method change made on one work's evidence.

Every work in the corpus has at least one secondary placement — 15 of 15. The strict partition required by the original design would have discarded information on **every single row**. That is not a marginal improvement to the axis; it is the difference between an axis that can support a composition argument and one that cannot.

A5 is never a primary. Not one system in this corpus is *evaluated* against an adversary below the harness, though seven acknowledge one in design. The sharpest instance is the

Intel TDX trusted plane: it is the only work in the set that **interposes** below the harness, and its evaluation still assumes an **A2** adversary. The construction reaches lower than the threat model it is tested against, which is a different failure from overclaiming and arguably a more interesting one.

A2 dominates at 10 of 15. The field is overwhelmingly organized around an adversary in the inputs — indirect injection — with the harness assumed trustworthy. That assumption is exactly what A4 denies, and it is the axis on which composition fails.

6.3 The compatibility matrix

Two controls compose only if their assumed adversary placements are compatible. A control that assumes the harness is trustworthy and screens what enters it, and a control that assumes the harness is compromised, do not compose: deploying both yields the weaker guarantee over any action reachable at the weaker placement, not the union.

✓ compose · △ conditional · × do not compose

The load-bearing cell is A2×A4. An A2 control's guarantee is stated over a trustworthy harness. An A4 adversary is inside that harness. Composing them does not produce defense in depth; it produces an A2 guarantee that is void under the A4 assumption the other control was purchased to address, and an A4 control whose input screening the A2 component was supposed to supply.

On the primary distribution, the corpus is mostly self-compatible and that is the problem. Ten of fifteen works are A2. Two A2 controls compose trivially and add little, because they share the same blind spot. The pairs that would add something — A2 with A4, A2 with A5 — are exactly the non-composing cells.

6.3.1 The named set

Applying the matrix to the 15 primary placements gives **105 pairs**:

Every one of the twenty is the same cell. All 20 non-composing pairs are **A2 x A4** — one of the ten works assuming

an adversary in the inputs, paired with one of the two assuming an adversary inside the harness. There is no second failure mode in this corpus. The composition problem is not diffuse; it is a single incompatibility, occurring twenty times.

And the two A4 works are the two you would most want. Only two systems in the corpus assume a compromised harness. Those are precisely the systems a practitioner would reach for to cover what an input-screening control cannot see — and they are the two that do not compose with the ten input-screening controls. **The pairing that would most improve a stack is the pairing the field cannot currently supply.**

The 66% that do compose are mostly **A2 x A2**. They compose because they share an assumption, and they add correspondingly little: two controls blind in the same direction give defense in depth against the threat both already handle and none against the threat neither does. **A high compose-rate is not a healthy corpus. It is a monoculture.**

The twenty, and why they are one cell: Adjudicated primary placements: **A4** — PAuth, Grimlock. **A2** — AARM, CaMeLs Can Use Computers Too, Caging the Agents, From Craft to Kernel, Heartbeat-Bound Credentials, MCP-SandboxScan, MiniScope, SEAgent, Sandlock, TDX trusted plane. **A1** — AgentCgroup. **A3** — Separation-of-Powers. The §9 system takes no placement in the composition matrix. $2 \times 10 = 20$ **A2 x A4 pairs**, which is the whole of the non-composing set.

The incompatibility is mechanical, not thematic. Placing the adversary in the inputs is not only a statement about where attacks originate. In all ten A2 works it is also a statement about where the *enforcement point* lives: each monitor decides over an **event vocabulary the harness supplies** — which call was made, with which arguments, against which plan, carrying which taint label, in which normalized form. The soundness of every such decision is conditional on that vocabulary being a faithful account of what is about to happen. **That conditional is the A2 assumption, and both A4 works deny it explicitly and in writing.**

The two A4 works deny it, verbatim: PAuth denies that *the harness's account of a call is authoritative*, and moves the decision out of the harness into middleware embedded in each participating server, deciding only over values arriving as signatures from other servers. Grimlock denies that *the runtime will present its actions to the mediation point at all*, and moves mediation below the runtime into eBPF interception plus an out-of-runtime guard in a separate confidential VM.

The starkest contradiction is textual and concerns one component. Sandlock's threat model places "the host kernel, the Sandlock supervisor, and the embedding agent runtime" in the **trusted** set; Grimlock names "a malicious or buggy agent runtime" as its **adversary**. These are contradictory axioms about the same component, not differing emphases.

What breaks, in four steps:

1. **The A2 monitor's premises become attacker-chosen, so its guarantee is voided rather than weakened.** An A4 adversary controls the *event the monitor sees*, not merely the data the agent reads: it can present a benign call to a decorator and issue a different one, hand an interpreter a

plan-conformant trace while acting off-plan, label tainted data untainted in the registry, normalize a harmful operation into a benign request before classification, or construct the graph the policy engine matches against. The monitor then returns *ALLOW correctly*, on a false premise. The failure is not a missed deny but a **manufactured allow**, and no tightening of the predicate reaches it.

2. **The A4 mechanism does not backfill the coverage the A2 work was relying on.** PAuth constrains only calls presented to a participating server; Grimlock constrains only flows crossing a sandbox boundary. Neither observes a local file write, a subprocess spawn including descendants, a package install, a sub-agent spawn, or a host-side credential read — precisely the remainder each A2 work left unmediated on the strength of the harness being honest. **The composed coverage vector is not the union of the two; it is the A4 work's vector alone**, because every cell the A2 work claimed rested on the antecedent the A4 work retracts.
3. **The two mechanisms cannot be told apart from each other's vantage point, so the composition does not type-check.** To Grimlock, an A2 monitor co-resident with the agent is inside one opaque, attested principal: the guard sees a flow from a sandbox, not a flow a monitor inside that sandbox approved, and it can neither protect the monitor nor read its verdict. To PAuth, an operand computed in the harness by an A2 mechanism — a plan-resolved coordinate, a minimized scope, a taint-cleared value, a rewritten parameter — carries no signed symbolic provenance and is rejected as off-slice; admitting it requires enrolling the harness as an envelope authority, reinstating exactly the trust PAuth withdrew. **Either the A2 mechanism is demoted to advisory or the A4 mechanism is demoted to a rubber stamp. There is no third arrangement.**
4. **The composed audit trail is weaker than either component's, not stronger.** Five of the ten A2 works emit records authored at a point inside the harness. A signature attests to the record, not to the event; under an A4 adversary those records are attacker-authored at capture even when correctly signed after capture, and a reader of the composed trail cannot tell which records crossed the A4 trust boundary. Accountability claims that hold separately do not survive the merge.

The ten A2 works, and what each composition loses: Each row below pairs with both A4 works, giving the twenty. The full per-pair justification with quoted spans from both sides is in the artifact.

(Table A1, appendix — 10 rows.)

Robustness of the count: The count depends on two adjudications where the coders disagreed, in opposite directions on the same species of evidence — a work's *credential and runtime* discussion read as a statement about the harness (A4) against its *injection* discussion read as the primary placement (A2). The code turns on which the evaluation actually exercises.

Neither flip changes the qualitative result — the cell is non-empty, and its members are non-composing for the reason

Work	Coder	placementSpan (verbatim)
PAuth (2603.17170)	charitable — primary A4	"Under our threat model, the agent is untrusted and may issue calls that deviate from the task for any reason. To evaluate PAuth without depending on a particular attack method, we construct adversarial tool calls for each task."
Grimlock (2605.27488)	charitable — primary A4	"We assume an active network adversary capable of eavesdropping, replay, relay/diversion, and man-in-the-middle attacks. We also consider a malicious or buggy agent runtime that may attempt to bypass mediation (e.g., direct sockets, alternate stacks) or escalate scope. We do not trust user-layer code to correctly implement identity or authorization, and we treat the host network and surrounding infrastructure as untrusted."
Grimlock (2605.27488)	conservative — primary A4	"We also consider a malicious or buggy agent runtime that may attempt to bypass mediation (e.g., direct sockets, alternate stacks) or escalate scope."

Work	charitable	conservative	adjudicated	effect if flipped
PAuth	A4	A2	A4	1 A4 × 11 A2 → 11 pairs
Caging the Agents	A2	A4	A2	3 A4 × 9 A2 → 27 pairs

given above — but the count is reported as **adjudicated rather than observed**, and the table travels with it.

Why the corpus produced this cell rather than avoiding it. A4 appears as a *secondary* placement in 10 codings across 7 works. The corpus is not unaware that the harness is a threat; it declines to place it primary, because doing so would invalidate the enforcement point each work has chosen. The non-composition is therefore not an oversight in a few papers. It is the structural consequence of a shared design decision — put the monitor where the semantics are — meeting the one adversary that decision cannot survive.

6.4 Cross-cut against the reference-monitor properties

Each work assessed against tamperproof, always-invoked, small-enough-to-verify. **The "always invoked" property is where the coverage axis and the classical literature meet:** a control that mediates three of seven effectors is not always invoked, by definition, and its guarantee is therefore conditional on the agent not using the other four.

7. ENFORCEABILITY

Schneider's result bounds what an execution monitor can enforce: safety properties, and not more. We apply it to the claimed policies in the corpus.

7.1 ★ The binary was the wrong question, and the answer is universal

§7 was drafted expecting to sort claimed policies into *enforceable* and *not enforceable*.

Across both passes, 50 of 50 codings returned neither. The pilot's 20 of 20 invited the obvious objection that it had sampled only proxy-tier systems. The decisive pass answers it: the set includes a Landlock/seccomp sandbox, an eBPF cgroup controller, a WASI runtime, an Intel TDX trusted plane and three signature-based capability protocols. **Every one returned split.** Zero enforceable, zero non-enforceable, both stances, all works.

§7.2's prediction that split would be "modal" is too weak. On the evidence to date it is **universal**, and that is a categorically different claim: not that most systems enforce a surrogate, but that **every system examined does**, across every enforcement tier the corpus contains. Every coding, on every work, across both stances, returned **partial** — and independently described the same structure:

*The object the monitor mechanically enforces is a **prefix-closed safety property over a per-call predicate**. The objective the paper advertises is an **information-flow hyperproperty** that no execution monitor can decide.*

That two opposed-stance coders located the same split, in the same place, on every work, is the strongest agreement signal in the pilot — stronger than the 100% tier agreement, because it is agreement on a *decomposition* rather than on a label.

7.2 The three-value column

The Schneider column therefore takes three values, and **split is expected to be modal**:

7.3 Why the split is the finding

A work classified *split* is not weakly enforced. It is enforcing something **real and narrower than what it claims**, and the distance between the surrogate and the objective is where the residual attack surface lives. Naming that distance per work is more useful to a practitioner than a verdict, and it is not available from any existing systematization of this literature.

It also sharpens §5.3. A field that is 98% unreviewed, in which every pilot work advertises an objective its own mechanism cannot decide, is not a field with a few overclaiming papers. It is a field with a systematic gap between advertised objective and enforced surrogate — and that gap, not the tier delta, may be the paper's central contribution.

7.4 The full distribution

Distribution across the three values: enforceable 0, split 50, non-enforceable 0, over 50 codings. No work in the corpus lacks an identifiable surrogate. The closest case is MCP-SandboxScan, whose surrogate is a detector rather than an enforcer (§7.4.6), and even there a mechanically checked predicate exists. The per-work naming below is reconciled from the 30 codings that carry a *schneider* object — two opposed-stance coders over all fifteen works.

7.4.1 The surrogates fall into four shapes, not fifteen: This is the stronger finding and it leads the subsection. Fifteen mechanisms, described in fifteen vocabularies, enforce four things.

Secondary occurrences reinforce rather than dilute the partition: S2 appears as a conjunct inside MCP-SandboxScan

Value	Meaning
Enforceable	The claimed policy is a safety property a monitor can enforce
Split	A monitorable safety surrogate is enforced; a non-monitorable objective is advertised
Non-enforceable	The claimed policy lies outside the enforceable class and no surrogate is identified

Shape	Definition	Works	n
S1 — Per-event admissibility predicate at an application chokepoint	One event tuple (call, request, connection) tested against a granted set, a compiled rule or a presented credential; decidable at interception from local state	MiniScope, SEAgent, AARM, PAuth, the section 9 system, Separation-of-Powers, TDX trusted plane, Heartbeat-Bound Credentials, Grimlock	9
S2 — Kernel or OS capability bound over a process tree	Path, port, syscall, IPC or resource limits enforced below the runtime and inherited by descendants	Sandlock, Caging the Agents, AgentCgroup	3
S3 — Prefix-closed automaton over a plan or instruction stream	A grammar, FSM or plan graph the trace must conform to; violation has a finite bad prefix	CaMeLs Can Use Computers Too, From Craft to Kernel	2
S4 — Single-run positive-evidence observation predicate	A detector: a witness is reported if observed; absence of a witness proves nothing	MCP-SandboxScan	1

(the WASI grant) and inside Caging the Agents; S3 appears as a conjunct inside MiniScope and inside Separation-of-Powers; S1 appears as a conjunct inside Sandlock, in the user-notification supervisor's per-syscall Allow/Deny/Continue.

Every S1 instance shares four structural traits: interception before effect, a predicate over one event, evaluation against a set fixed earlier in the session, and a decision that is sound only if the event presented is the event that will occur. The last trait is where §6.3.1 attaches.

7.4.2 The objectives fall into four shapes, and eleven of fifteen carry an information-flow conjunct: (Table A2, appendix — 4 rows.)

7.4.3 The pairing matrix: sixteen cells available, eight occupied: The modal cell is S1 × O1 at four works outright, and seven of the nine S1 works advertise an information-flow objective once conjuncts are counted. That cell is the authorization–execution gap seen from the Schneider side: **a predicate on one authorized event, advertised as a property of where data ends up.** The tier instrument and the enforceability instrument are therefore not two readings of one observation — they are two independent measurements that converge on the same population.

7.4.4 Per work: the surrogate enforced against the objective advertised: (Table A3, appendix — 15 rows.)

7.4.5 The residual surface: five shapes, and two of them are the gap: The distance between surrogate and objective is not undifferentiated. It resolves into five recurring residual shapes; every work falls into at least one and most into two or three. Quotations are verbatim from the codings, which in turn quote their sources.

(Table A4, appendix — 5 rows.)

R1 and R2 are the two halves of the authorization–execution gap. R1 is what remains when acceptance is bound correctly and action is unbounded *within* the accepted scope; R2 is what remains when the action surface is *wider* than the acceptance surface. Eleven of fifteen works exhibit one or both. R3 and R4 are the reasons the surrogate cannot simply be tightened to close R1: the referent is not computable, and the data is laundered through a component that is in the trusted set by necessity rather than by argument.

7.4.6 Coder divergence, and the two outliers: The verdict is robust at 30 of 30; the taxonomy of why is robust at 12 of 15.

Twelve works show agreement on both halves, differing only in partition or specificity. Three — AgentCgroup, PAuth and Heartbeat-Bound Credentials — show substantive divergence, and in all three the disagreement is not about whether the verdict is split but about which non-enforceability applies: a hyperproperty against a liveness reading (AgentCgroup), a translation step in the trusted computing base against an unmediated call surface (PAuth), a bounded-window residual against a quantifier over all effect channels (Heartbeat-Bound Credentials). Reporting that separation matters: a systematization that claims a uniform verdict and a uniform explanation is claiming more agreement than the codings support.

Two works do not fit the modal reading, and saying so strengthens the shape vocabulary rather than weakening it. **AgentCgroup** is the only work whose objective is neither information flow nor intent; its objective is operational, its unenforceability partly liveness rather than hyperproperty, and it is also the only work whose primary adversary placement is A1. **MCP-SandboxScan** is the only work whose surrogate is a detector rather than an enforcer: its own text concedes that absence of a witness does not prove absence of a flow, so its surrogate does not bound even the trace it observes, let alone the deployed one. It is the only work in the corpus that enforces nothing at deployment time. Both are correctly coded split; each is evidence that the shape vocabulary needs four entries rather than one.

8. EMPIRICAL ARTIFACT

A small demonstration, one representative system per tier, showing bypass of the advertised guarantee.

Deferred, and stated as deferred. A bypass demonstration on representative systems, one per tier, would convert this paper from analysis into analysis-with-evidence, and it does not fit the present cycle. It is named here rather than omitted because the weakest-link rule makes a falsifiable prediction — a system scored B-T3 should fall to a subprocess spawn that never traverses its chokepoint — and the honest position is

	O1 information flow	O2 intent / least privilege	O3 provenance	O4 cross-execution	row n
S1 per-event admissibility	MiniScope, AARM, TDX trusted plane, Grimlock — 4	SEAgent, PAuth, Separation-of-Powers — 3	the section 9 system — 1	Heartbeat-Bound Credentials — 1	9
S2 kernel capability bound	Caging the Agents, Sandlock — 2	—	—	AgentCgroup — 1	3
S3 plan / instruction automaton	CaMeLs, From Craft to Kernel — 2	—	—	—	2
S4 single-run detector	MCP-SandboxScan — 1	—	—	—	1
col n	9	3	1	2	15

that the prediction is published before the demonstration, not after.

Why this exists. It converts the paper from analysis into analysis-with-evidence, and it is the difference between a borderline and a clear accept. It also disciplines the weakest-link rule: if the rule predicts a system is proxy-tier, a subprocess spawn should defeat it, and that is demonstrable rather than argued.

9. APPLYING THE RULE TO A SYSTEM THE AUTHORS KNOW WELL

Double-blind note (strip at camera-ready, replace with disclosure). This section is written in third person per §3.5.1. One scored system is the authors'; the relationship is declared to the chair through the conflict-of-interest mechanism and disclosed in the camera-ready. Nothing in the scoring procedure differs for it.

System W issues cryptographically signed warrants and produces tamper-evident action receipts. Those are genuine T1 mechanisms and they constrain what a verifier will accept. **They do not constrain execution.** The enforcement point is a protocol-layer handler, and an agent holding a shell does not consult it. The published architecture contains no namespace, seccomp or firewall mechanism.

Scored: A-T1 of acceptance, B-T3 of action. Its receipts and warrants are cryptographically verifiable — forging what a relying party accepts requires breaking a signature. Its enforcement point is a protocol handler, and the cheapest defeat of an *action* bound is a subprocess spawn that never traverses it.

△ **The system is a textbook instance of the authorization-execution gap in §5.3A**, and under the single-column rule that fact was invisible: the system scored a flat T3 alongside works whose cryptography is decorative. The two-column rule states the position exactly, and it is less flattering in one respect and more accurate in both — the cryptography is real, and it is answering a question about acceptance while the deployment needs one about action.

Coverage, on ACTION-SURFACE-v1.0: the protocol-declared surface only. E2 subprocess spawn, E3 descendant egress, E5 package install and E6 credential use fall outside it unless the deployment composes an operating-system boundary the system does not itself provide.

Adversary placement: A2. The threat model assumes the harness is trustworthy and screens what enters it. Against A4 — an adversary inside the harness — the guarantee does not hold.

Evidence grade: L1 — source inspection. The guarantee has not been tested to L2 or broken to L3.

This row is presented early and in full because a systematization that adjudicates other people's guarantees should demonstrate the rule producing an unflattering result before it produces flattering ones.

10. LIMITATIONS

The coverage axis is a measurement we perform, not one the field reports. Its validity rests entirely on the frozen enumeration, the two-coder procedure and span traceability. A different enumeration would produce different numbers, and the enumeration is a judgment.

Scoring is adversarial by design and therefore contestable. We score guarantees at the tier where we believe they fall. Authors may disagree, and the published spans exist so that disagreement can be specific rather than general.

The corpus is a preprint-heavy population in a field publishing monthly, frozen at a date.

We are not neutral. The authors build in this space. §9 and the procedural safeguards in §4 are the mitigation; they are not a solution, and a reader should weight the scoring accordingly.

Machine coding with human verification. All coding was performed by opposed-stance LLM agents; the nine works carrying headline findings are human-verified against recorded spans (§3.5.2). Agreement figures are reported as stance-divergence measurements and as upper bounds on reliability, never as inter-coder reliability. **Human verification: ___ of 9 load-bearing rows verified, ___ overturned.** The nine works carrying headline claims are verified by a human coder against the recorded verbatim spans before submission. The overturned count is reported here whatever it is; a count of zero is stated together with the reason it is credible, since a verification layer that never overturns anything is indistinguishable from one that was not performed.

Corpus size and selection. Fifteen works, selected for tier-axis power rather than sampled. The contribution is adjudication rather than enumeration, and the population is stated rather than implied — but a reader who wants a census of this literature should read the prior systematization, which we cite and do not attempt to replace.

11. RELATED WORK

11.1 The competing systematization

The closest prior systematization of this literature is arXiv:2607.05743 (July 2026), which sorts thirty-nine execution-security papers from 2023–2026 into seventeen mechanism categories, re-reads them against four root causes

and a pre-action / at-action / post-action pipeline stage, and derives five cross-cutting gaps. Its verification protocol establishes each entry's bibliographic identity and then, in its own words, reports every empirical claim as stated by that paper's authors. **That sentence is the boundary this paper works on the other side of:** an audited index of what papers say about themselves is a different object from an adjudication of whether those claims hold, and a protocol that records what an author claims cannot yield §5.4's count of works binding lower than they claim.

Priority for systematizing this subject belongs to that work and is not contested. Its fragmentation thesis is its own, as are RC2 ("authorization is checked once and trusted forever") and RC3 (a mechanism encodes whether an action is *permitted*, not whether *this* invocation matches intent). The authorization–execution gap of §5.3A is a claim about the **strength of a binding** — verified at cryptographic tier, bounded only at an application chokepoint — and is neither RC2's staleness nor RC3's intent mismatch. Its two headline figures carry limits worth stating: the 69.0%–98.6% fragility range is over **1,709 scraped command denylists**, and the 17.1% overeager-action figure is a prompt ablation on one product rather than a base rate.

On composition, that work asks the question this one answers. Its Gap 1 asks whether isolation architectures and capability models are substitutes or complements, and its Figure 18 scores all 17×17 category pairs — for similarity, which is not compatibility. No specific pair of systems is adjudicated there. The twenty non-composing pairs of §6.3.1 answer a published open problem from a disjoint sample rather than stating it first.

The two corpora are nearly disjoint, and that cuts both ways. Of the fifteen systems scored here, exactly one — SEAgent — appears among that work's thirty-nine, a sample holding none of the information-flow, capability-DSL and provenance strand that dominates this one. They are better read as independent samples of one field than as competing readings of one sample, and the consequence is a coverage-validity question about **both**, which §10 records against this one rather than leaving it to be raised asymmetrically. The shared row states the difference in a line: that work classifies SEAgent by the mechanism it proposes, as access control and capability, while the coding here records that its mandatory access control has no kernel, no label store and no reference monitor below the process.

11.2 Formal analysis of protocol composition

AgentThread compiles normative clauses from five agent protocol specifications into TLA+ invariants, model-checks them with TLC, and replays counterexamples against production SDKs: thirty-five specification-level findings, eighty implementation tests, and thirty of forty-three security obligations admitting counterexamples across eight composed protocol pairs. Its Responsibility IR reaches a conclusion this paper corroborates: exactly one security-relevant control across

those protocols is both owned and enforced, and none assigns enforcement for cross-protocol behavior.

The two differ in unit and in axis. AgentThread adjudicates specifications against their SDKs under a protocol-level Dolev-Yao adversary, with transport security an assumed substrate and the layer stack beginning at message integrity; placement there is a fixed assumption, never a variable, and nothing beneath the protocol layer is modeled. This paper adjudicates deployed systems and scores placement, including placements beneath the harness. AgentThread's enforcement vocabulary is absent / partial / enforced, with no scale on which a cryptographic bound, an operating-system bound and an in-process check differ in kind, and the consequence is visible in its own results. Its one positive finding is that DID-based identity verification "provides no mechanism to bound content integrity or delegation scope": the authorization–execution gap, witnessed at the protocol layer by an independent group, in their own data, and left unnamed.

Two vocabulary collisions are flagged rather than left to a reader. That work's gap taxonomy already contains *split-duty* and *enforcement gap*, whereas §7's *split* means a monitorable safety surrogate enforced beneath a non-monitorable advertised objective, and is defined at first use for that reason. Its composition is between two *protocols*; the twenty failing pairs of §6.3.1 compose two *adversary placements*.

11.3 Runtime invariants, evidence sufficiency, injection defense

Execution-control invariants. HCP, a reference runtime for MCP-style agent execution, names eight execution-layer invariants, from metadata non-authority and grant-backed approval through source-and-target data-flow authorization to deny-path audit, and benchmarks them over ten adversarial cases with a per-component ablation, blocking ten of ten where a practice-informed baseline blocks four. Its second invariant, that approval cannot substitute for a grant, is one half of the distinction developed here, expressed within a single process, and is cited where the gap is introduced. It does not reach the other half: its runtime, policy engine, grant store and audit log are trusted by assumption and share an address space with the providers they mediate, so every invariant is a predicate the application tier evaluates about itself. Scored on the two-column rule it lands at A-T3/B-T3 — the clearest demonstration that tier consistency can be obtained by leveling downward rather than by binding anything: consistency is not what this literature lacks.

Evidence sufficiency. DEMM-Bench asks whether agent-runtime records across eight evidence regimes suffice to reconstruct decision-level properties, and reports container-presence baselines declaring sufficiency on 75% of a synthetic corpus in which a required property is missing. Its *container fallacy* and *Decision Evidence Gap* are named prior art for the premise that an evidence container is not the property it is taken to establish, and its graded verification-strength family — cryptographically bound through merely narrated — is the closest structural neighbor to the acceptance column here. The two divide on the object scored: that work scores the

reconstructability of a record after a decision, over adversary-free degradations of synthetic cases. The division is load-bearing, because a record can bind every property of a decision that was never mediated at all. It has no effector model, no adversary and no action column, and its weakest property family is *action boundary*, at 0.25 property-sufficiency accuracy.

Runtime injection defense. ClawGuard interposes middleware at the tool-call dispatch boundary of a production harness, evaluating each proposed call against a rule set whose task-specific half is induced from the user's stated objective before the first tool runs, over six benchmarks, 1,734 attack scenarios and five backbones. It scores A-T3/B-T3: acceptance decided by pattern matching and a model judge running inside the process under attack, actions bounded at the harness dispatcher, so a permitted `exec`, its descendants and any egress they perform leave the mediated set. Two of its results discipline claims made here. Its channel asymmetry — the same objective is roughly thirty points more effective in a skill file or a tool description than in retrieved content — is evidence that placement rather than payload is the dominant variable, the premise of §3.3. And its six residual failures, which succeed without issuing a suspicious tool call at all, mark where an action-bounding instrument stops applying: where no effector is reached there is no action to bind, which is why §2.2 draws the content-control exclusion on the effector boundary.

11.4 Where this paper is not novel

Stated plainly, because a reviewer holding these works will check. **That composition between agent components is underspecified, unowned and formally broken is Agent-Thread's finding, not this paper's** — including the coined *composition-orphan* gap type and the conclusion that the security-critical logic sits in bridges neither side's specification governs. The five gaps of arXiv:2607.05743, its fragmentation thesis, its root causes, its pipeline framing and its incident grounding are its own. Overclaim as a quantified diagnostic, the trivial-anchor discipline that accompanies it, and a property decomposition of the governance record belong to DEMM-Bench, and the demotion statistic of §5.4 is structurally an overclaim measurement. Separating approval from authorization, and treating data movement as a fresh authorization event, are ablated invariants in HCP. And no claim that this literature bounds nothing is available: eleven of fifteen systems bound actions at an application chokepoint, and the corpus's strongest empirical bounding result comes from a system with no cryptography in it anywhere.

11.5 The classical spine

Four classical results do positioning work throughout and are never scored as rows. **Complete mediation** is the property the coverage axis measures the absence of; that 2 of 105 cells reach covered is a statement about complete mediation, not about mechanism quality. **Confinement**, in Lampson's sense, names what an application-tier control cannot achieve, and is why the action column distinguishes a chokepoint from a kernel bound at all. **Schneider's enforceability result** bounds what any

execution monitor can enforce and supplies §7 its instrument; the universal `split` verdict is a statement in that vocabulary rather than a new one. **Anderson's three reference-monitor properties** — tamperproof, always invoked, small enough to verify — provide the cross-cut of §6.4, where *always invoked* is what a partial coverage vector denies. The claim is not that these principles apply to agents, which is uncontroversial, but that a corpus can be scored against them with a per-cell audit trail — which orders the literature differently than its abstracts do.

Reads that discharge debt elsewhere in the companion studies. HCP (arXiv:2606.29073), DEMM-Bench (arXiv:2606.20634) and ClawGuard (arXiv:2604.11790) are all in-corpus rows under G1–G4. Reading them inside this schedule costs nothing additional and settles open positioning questions for two other papers at the same time.

APPENDIX

Reviewers are not required to read appendices. Every finding in this paper is argued in the body; the material below is the evidence a reader may wish to check. Per-cell verbatim spans are in the released artifact.

- A1. *The twenty, and why they are one cell*
- A2. *7.4.2 The objectives fall into four shapes, and eleven of fifteen carry an information-flow conjunct*
- A3. *7.4.4 Per work: the surrogate enforced against the objective advertised*
- A4. *7.4.5 The residual surface: five shapes, and two of them are the gap*

REFERENCES

- [CaMeL] Edoardo Debenedetti et al. *Defeating Prompt Injections by Design*. arXiv:2503.18813, 2025.
- [Progent] Tianneng Shi et al. *Progent: Securing AI Agents with Privilege Control*. arXiv:2504.11703, 2025.
- [DesignPatterns] Luca Beurer-Kellner et al. *Design Patterns for Securing LLM Agents against Prompt Injections*. arXiv:2506.08837, 2025.
- [AgentArmor] Peiran Wang et al. *AgentArmor: Enforcing Program Analysis on Agent Runtime Trace to Defend Against Prompt Injection*. arXiv:2508.01249, 2025.
- [MiniScope] Jinhao Zhu et al. *MiniScope: A Least Privilege Framework for Authorizing Tool Calling Agents*. arXiv:2512.11147, 2025.
- [MCP-SandboxScan] Zhuoran Tan et al. *MCP-SandboxScan: WASM-based Secure Execution and Runtime Analysis for MCP Tools*. arXiv:2601.01241, 2026.
- [CaMeLs Can Use Computers Too] Hanna Foerster et al. *CaMeLs Can Use Computers Too: System-level Security for Computer Use Agents*. arXiv:2601.09923, 2026.
- [SEAgent] Zimo Ji et al. *Taming Various Privilege Escalation in LLM-Based Agent Systems: A Mandatory Access Control Framework*. arXiv:2601.11893, 2026.
- [AgentCgroup] Yusheng Zheng et al. *AgentCgroup: Understanding and Controlling OS Resources of AI Agents*. arXiv:2602.09345, 2026.
- [AARM] Herman Errico. *Autonomous Action Runtime Management(AARM):A System Specification for Securing AI-Driven Actions at Runtime*. arXiv:2602.09433, 2026.

A2 work	Where its monitor sits	The harness component whose honesty its guarantee requires	What the composition loses
MiniScope	In the agent's own process	A decorator wrapping each MCP function, and the routing of calls through it	The decorator is bypassed by construction; only credential isolation survives, and its coarse OAuth scopes do not reconcile with PAuth's exact operand matches or with Grimlock's scope tokens
CaMeLs	In the harness	The plan interpreter, and the Q-VLM path resolving runtime operands	CFI is a property of the interpreter's own execution; runtime-resolved operands carry no envelope provenance, and a computer-use agent's effectors are overwhelmingly local, so its principal action surface is mediated by neither
SEAgent	In the framework	The System View graph built from declared invocations and messages	A falsified graph plus SEAgent's documented default-allow converts to a manufactured allow; the inter-agent messages Grimlock mediates are validated by token, not by graph path
From Craft to Kernel	Between the model and its effectors	The reification step producing typed instructions, and the taint registry	The taint label is harness state: cleared in place, "no tainted data reaches a Sink" holds vacuously over a falsified dependency graph; effects that never leave the sandbox are structurally invisible to a network guard
AARM	In band, by design	Gateway, SDK instrumentation or vendor hook — all three conformant architectures are in band	AARM's own text disqualifies kernel-level implementations for context-dependent decisions, which is exactly Grimlock's mechanism; its MODIFY and STEP_UP rewrites produce operands PAuth must reject, so the composed system deadlocks on every modified action
TDX trusted plane	Split	The REE-side gate that extracts and normalizes the operation before classification	An adversary at the extraction step obtains a <i>valid</i> , fresh, scope-bound authorization for a harmful operation presented as a benign one
Heartbeat-Bound Credentials	At the verifier	That the agent presents a proof at every privileged action	Under A4 the proof is simply not presented where inconvenient; the composed bound reads "fresh within the window on participating servers, unbounded elsewhere" — neither work's advertised claim
Sandlock	Split	The kernel layer sits below the runtime, but the supervisor in the trusted parent answers every runtime-dependent decision	Landlock and seccomp survive; the resolved connect destination, the HTTP method/host/path check and the execve argv check are answered where the A4 adversary sits
Caging the Agents	Layered	L1–L3 sit below the agent; L4 is framework-injected trusted metadata authored in the harness	L4 provides nothing once the adversary authors the envelope; L1–L3 remain blast-radius bounds and are not call-level authorization, so the allowlisted destinations through which the paper concedes PHI can lawfully leave are unbounded by either work
MCP-SandboxScan	Outside deployment	The audit harness, and the inference that audited behavior predicts deployed behavior	The witnesses are captured in a harness the A4 adversary controls, so they no longer bind even the observed run; absence of a witness never proved absence of a flow

Shape	Definition	Lead objective in	Present as a conjunct in	n (lead)
O1 — Information flow / non-interference	Non-leakage, non-exfiltration, confidentiality, PHI non-disclosure, taint-to-sink non-influence. A hyperproperty over sets of executions	MiniScope, MCP-SandboxScan, CaMeLs, AARM, Caging the Agents, From Craft to Kernel, TDX trusted plane, Sandlock, Grimlock	SEAgent, Separation-of-Powers, PAuth (need-to-know)	9
O2 — Intent alignment, task faithfulness, least privilege against an unobservable oracle set	Whether an action serves what the user meant; membership in a minimal action set that is oracle-defined	SEAgent, PAuth, Separation-of-Powers	MiniScope, AARM, Caging the Agents, TDX trusted plane, CaMeLs	3
O3 — Truthful provenance and accountability	That the recorded chain corresponds to what the agents did. A correspondence claim about records, not a flow claim about data	The section 9 system	Grimlock, Separation-of-Powers, TDX trusted plane	1
O4 — Cross-execution operational objective	Performance isolation between co-located tenants; deterministic termination of a swarm. Not a single-trace property, and in part liveness rather than safety	AgentCgroup, Heartbeat-Bound Credentials	—	2

[PAuth] Reshabh K Sharma et al. *Beyond OAuth: Task-Scoped Authorization for AI Agents via Natural Language Slices*. arXiv:2603.17170, 2026.

[Caging the Agents] Saikat Maiti. *Caging the Agents: A Zero Trust Security Architecture for Autonomous AI in Healthcare*. arXiv:2603.17419, 2026.

[AIP] Sunil Prakash. *AIP: Agent Identity Protocol for Verifiable Delegation Across MCP and A2A*. arXiv:2603.24775, 2026.

[ClawGuard] Wei Zhao et al. *ClawGuard: A Runtime Security Framework for Tool-Augmented LLM Agents Against Indirect Prompt Injection*. arXiv:2604.11790, 2026.

[From Craft to Kernel] Xiangyu Wen et al. *From Craft to Kernel: A Governance-First Execution Architecture and Semantic ISA for Agentic Computers*. arXiv:2604.18652, 2026.

[Separation-of-Powers] Rong Xiang. *Structural Enforcement of Goal Integrity in AI Agents via Separation-of-Powers Architecture*. arXiv:2604.23646, 2026.

[TDX trusted plane] Di Lu et al. *Constraining Host-Level Abuse in Self-Hosted Computer-Use Agents via TEE-Backed Isolation*. arXiv:2605.06393, 2026.

[Heartbeat-Bound Credentials] Saurabh Deochake. *Heartbeat-Bound Hierarchical Credentials: Cryptographic Revocation for AI Agent Swarms*. arXiv:2605.20704, 2026.

[Sandlock] Cong Wang, Yusheng Zheng. *Sandlock: Confining AI Agent Code with Unprivileged Linux Primitives*. arXiv:2605.26298, 2026.

[Grimlock] Qiancheng Wu et al. *Grimlock: Guarding High-Agency Systems with eBPF and Attested Channels*. arXiv:2605.27488, 2026.

[DEMM-Bench] Oleg Solozobov. *DEMM-Bench: A Cross-Regime Benchmark for Agent-Runtime Governance-Evidence Sufficiency*. arXiv:2606.20634, 2026.

[HCP] Ting Liu. *From Tool Connection to Execution Control: Benchmarking Security Invariants in MCP-Style Agent Runtimes*. arXiv:2606.29073, 2026.

[PriorSoK] Mohammadreza Rashidi. *The Balkanization of Execution-Security Research for AI Coding Agents: Isolation, Access Control, and Time-of-Check-to-Time-of-Use Vulnerabilities*. arXiv:2607.05743, 2026.

#	Work	Surrogate the monitor mechanically enforces	Objective the paper advertises
1	MiniScope	Per-call scope membership at an in-process decorator wrapping each MCP function: every executed call lies in the permission state accumulated from the user's allow/deny decisions, plus credential substitution	Damage confinement under an unreliable model — no task misaligned with user intent, and no leak of sensitive data through connected services
2	MCP-SandboxScan	A WASI capability grant checkable per operation (env allowlist, one preopened directory, bounded streams, network denied by default), conjoined with a single-run canary-witness predicate over extracted LLM-visible sinks	Absence of confused-deputy flow from attacker-controlled external input to LLM-visible fields — non-interference between authority-bearing sources and the reasoning context
3	CaMeLs Can Use Computers Too	Control-flow integrity over a plan graph emitted before any untrusted data is observed; the plan interpreter is the reference monitor, and an unplanned call or branch is a finite-prefix violation	That untrusted environment content cannot determine what the agent does — which requires data-flow security as well as control-flow integrity
4	SEAgent	Per-invocation graph-path policy match over the current-round System View graph; deny where a prohibited attribute pattern evaluates true, default-allow where no policy matches	Least privilege relative to an oracle-minimal action set, and user-level non-interference
5	AgentCgroup	Per-cgroup resource ceilings at kernel allocation and scheduling points: a memcg BPF throttle delay, cgroup.freeze and cgroup.kill over a subtree, sched_ext dispatch prioritization	Multi-tenant isolation in which all concurrent sessions complete with accumulated context preserved, achieved by the agent voluntarily reconstructing a cheaper strategy after feedback
6	AARM	Pre-execution interception at a chokepoint, then a five-valued decision over (tool, operation, parameters, identity) against static policy and a predicate over an append-only hash-chained session log, with identity freshness, a semantic-distance threshold and a signed receipt	Prevention of compositional exfiltration — that no sequence of individually permitted actions effects a leak — conjoined with intent alignment
7	PAuth	Per-call default-deny exact rule match at server-embedded middleware: the operator appears in allowed_calls, every operand equals the concretized slice expression derived from signature-verified envelopes, and the conjoined assert guards hold	Faithful execution of the user's signed natural-language task with minimal, non-residual authority, plus need-to-know disclosure
8	Caging the Agents	Kernel, network and credential properties: no syscall from the agent or a descendant reaches the host kernel except through the gVisor Sentry, no packet leaves a pod outside its NetworkPolicy allowlist, no raw API secret resides in the agent container	That protected health information never flows to an unauthorized party, and that the agent acts on instructions from its legitimate owner rather than on injected or spoofed ones
9	The section 9 system	Per-invocation token-chain validation at a verifier: every block signature validates against a resolved identity document, each delegation's scope, budget and expiry is a subset of its parent's, declared depth is within max_depth, the token is unexpired, every block carries a non-empty context string	Truthful provenance and accountability — who authorized the action, through which agents it flowed, what constraints applied at each hop, what the outcome was, whether it was independently verified — plus the implied objective that granted authority is not misused
10	From Craft to Kernel	Two prefix-decidable conjuncts: no instruction designated a Sink executes while an argument carries an uncleared taint label, and no trajectory prefix violates the right-linear-grammar workflow policy	That untrusted or confidential data never influences sensitive operations — noninterference between tainted sources and sink-visible effects
11	Separation-of-Powers	Per-step reference monitor over a typed intent stream: schema and type check, deterministic MinimalCapSet lookup, SHA-256 lineage-anchor equality, a goal-drift similarity threshold, a shutdown-resistance veto, an SMT constraint check, a hard-auth veto, and capability-token presentation at dispatch with subset attenuation	"Goal Integrity" — that executed actions are semantically faithful to the originating intent and that outputs carry no coercion and no unauthorized disclosure
12	TDX trusted plane	Per-operation pre-execution authorization: no protected host resource is touched by a constrained executor unless the pending action matches a fresh, non-replayed, scope-bound authorization for that exact action / object / scope / context / sequence tuple, plus mandatory-deny classes	Prevention of host-level abuse, defined to include confidentiality loss, externalization of protected resources, consistency with the current task, and multi-step chains whose combined effect exceeds any single step
13	Heartbeat-Bound Credentials	Per-request local freshness and signature check: reject any proof whose parent heartbeat epoch is older than the window by the verifier's own clock, whose heartbeat or child signature fails, or whose issuance binding does not match. Purely local state	Deterministic termination of the agent swarm — that once the operator stops the orchestrator, no descendant performs any privileged action after the window closes
14	Sandlock	Per-process-tree kernel capability bound: no filesystem operation outside granted path prefixes, no connect outside the pinned endpoint allowlist, no IPC outside the Landlock scope, no syscall in the seccomp deny set, no fork past the process cap. Landlock and seccomp are the monitor, inherited by the whole tree	Prompt-injection resistance via capability separation — that private data reached by one stage does not flow to an external party
15	Grimlock	Per-connection release predicate at an out-of-runtime guard: no plaintext is released into a destination sandbox unless attestation appraisal succeeded under operator policy and the scope token's scope, audience, expiry and TLS-exporter channel binding all validate; plus no-bypass of the guard	Identity, authorization, provenance and delegation enforced consistently under least privilege across a delegated multi-agent, multi-cloud graph, with auditability

Shape	The residual attack	Works	n	Representative quotation
R1 — In-scope misuse	The honest, correctly authorized call that is nonetheless harmful. The predicate holds; the objective fails	MiniScope, the section 9 system, PAuth, Grimlock, SEAgent, Caging the Agents, Sandlock, AARM	8	"an agent legitimately holding a narrow scope can still move arbitrary information to any peer that scope permits" — Grimlock, conservative
R2 — Unmediated path	The effector is reached without traversing the monitor at all; the predicate is never evaluated	MiniScope, Heartbeat-Bound Credentials, Grimlock, MCP-SandboxScan, PAuth, AARM	6	"any authority exercised without network egress (local file write, local process or sub-agent spawn, host-side IPC) is not an event the monitor ever sees" — Grimlock, charitable
R3 — Laundering through the model	Tainted content is re-derived by an untracked reasoning step, or a semantic decision is delegated to a probabilistic judge inside the trusted component	From Craft to Kernel, AARM, CaMeLs, Separation-of-Powers, TDX trusted plane, PAuth	6	"Tracking data flow is complicated when data passes through an LLM's context window, where it may be transformed, summarized, or paraphrased." — AARM
R4 — Uncomputable referent	The objective names a set no monitor can decide membership in: the oracle-minimal action set, the user's true intent	SEAgent, PAuth, Separation-of-Powers, AARM, MiniScope, TDX trusted plane	6	"T _q is oracle-defined and often not known in advance, making defense against such attacks challenging" — SEAgent
R5 — Cooperation dependence	The upward half of the protocol depends on the agent volunteering true information about itself	AgentCgroup, the section 9 system	2	"Declarations are advisory; the feedback loop corrects underestimates." — AgentCgroup